

RAPPORT D'AUDIT GRC

Gouvernance, Risques et Conformité

[Document de Synthèse Stratégique & Plan de Traitement]

Organisation cible :	AeroForge (Fictif)
Secteur d'activité :	Industrie (Sous-traitant aéronautique)
Auteur / Consultant :	Valérien Jouen
Date du rapport :	Mai 2026

Sommaire

Note de lecture & Mode d'emploi	3
1. Synthèse pour la Direction	4
1.1 En quelques mots (Executive Summary)	4
1.2 Niveau de risque global	4
1.3 Les priorités immédiates (24h - 72h)	5
2. Contexte et périmètre de la mission	6
2.1 Objectifs de la démarche GRC	6
2.2 Spécificités du secteur d'activité	6
2.3 Périmètre de l'évaluation	6
2.4 Méthodologie retenue	7
3. Cadre réglementaire et normatif applicable	8
3.1 Le RGPD	8
3.2 La Directive NIS 2	8
3.3 Référentiels et bonnes pratiques sectorielles	9
4. Scénario Stratégique, l'évaluation de la gravité	9
4.1 La source de risque	9
4.2 Cibles et impacts métiers	9
4.3 Échelle et évaluation de la gravité	9
5. Construction du Scénario Opérationnel	10
5.1 Le cheminement de l'attaque	10
5.2 La cartographie du scénario avec MITRE ATT&CK	12
5.3 L'échelle d'évaluation de la vraisemblance	14
5.4 L'évaluation de la vraisemblance	15
6. Traitement des risques et Plan d'Action	15
6.1 L'évaluation du risque	15
6.2 Plan d'action	16
6.3 Évaluation du risque résiduel	17
7. Conclusion et recommandations stratégiques	17
7.1 Synthèse de l'analyse	17
7.2 Recommandations stratégiques	18
8. Annexes	19
8.1 Glossaire et définition	19
8.2 Références et sources	22

Note de lecture & Mode d'emploi

À propos de ce document

Ce rapport est un exercice de simulation réalisé dans le cadre d'une démarche de portfolio professionnel. Il a pour objectif de démontrer ma capacité à transposer des constats techniques complexes en une analyse de gouvernance, de risques et de conformité (GRC) actionnable et stratégique.

L'entreprise ciblée, « AeroForge » (sous-traitant aéronautique), son infrastructure industrielle, ainsi que les vulnérabilités présentées sont entièrement fictifs.

Méthodologie et Scénario

L'analyse présentée ici s'appuie sur la méthode EBIOS Risk Manager. Elle explore les risques critiques liés à la convergence des réseaux informatiques (IT) et industriels (OT). Le scénario central modélise une attaque par rançongiciel. Elle est initiée via la chaîne d'approvisionnement (supply chain), qui parvient à se propager jusqu'au système central de supervision (SCADA) et aux automates (PLC) de l'usine principale en raison d'un cloisonnement réseau historique trop permissif. Ce choix illustre la nécessité de protéger l'outil de production face aux menaces cyber modernes.

Public cible

Ce livrable a été rédigé pour être accessible aux instances décisionnelles. Il s'adresse en priorité à la Direction Générale d'AeroForge, à la Direction des Systèmes d'Information (DSI), à la Direction de l'Usine (Directeur de site/OT Manager), ainsi qu'au RSSI, en traduisant les constats techniques en impacts métier (arrêt de production, retards de livraison) et réglementaires (NIS 2).

1. Synthèse pour la Direction

1.1 En quelques mots (Executive Summary)

L'entreprise AeroForge a missionné un audit de sécurité sur son infrastructure informatique. L'audit a pour objectif de simuler les actions d'un attaquant afin d'identifier les failles avant que des individus ne les exploitent.

L'analyse révèle une exposition critique de l'outil de production industriel (OT). Le constat majeur réside dans la porosité historique entre le réseau bureautique (IT) et le réseau industriel, qui opèrent sans véritable cloisonnement. L'absence de défense signifie qu'une cyberattaque touchant un simple poste de travail ou un fournisseur partenaire (attaque par la *supply chain*) peut se propager sans obstacle jusqu'au cœur de l'usine. L'attaquant serait en mesure d'atteindre le système central de supervision (SCADA) et de paralyser l'ensemble des machines à commande numérique.

Une compromission par rançongiciel de l'outil de production entraînerait un arrêt total des machines pendant plusieurs jours, voire plusieurs semaines. Ce scénario expose directement à des pertes d'exploitation générant des pertes financières importantes pour les donneurs d'ordres aéronautiques, à une non-conformité à la directive européenne NIS 2, et produit un risque direct pour la sécurité physique des opérateurs sur site.

Il est nécessaire d'engager immédiatement un plan de remédiation stratégique. Ce dernier doit se concentrer sur la séparation des réseaux (IT/OT) et sur la structuration d'une gouvernance de sécurité à l'échelle de l'entreprise.

1.2 Niveau de risque global

Dimension évaluée	Niveau actuel	Niveau cible (12 mois)	Commentaire macro
Sécurité technique	Critique	Maîtrisé	Architecture historique et porosité extrême entre l'environnement bureautique et la chaîne de

Dimension évaluée	Niveau actuel	Niveau cible (12 mois)	Commentaire macro
			production.
Conformité Réglementaire	Insuffisant	Conforme	Les exigences de NIS 2 ne sont pas couvertes.
Gouvernance sécurité	Faible	Structuré	Absence de pilotage unifié de la sécurité.
Résilience	Inexistant	Opérationnel	Aucun plan de reprise d'activité n'est documenté en cas de compromission.

1.3 Les priorités immédiates (24h - 72h)

- **Priorité 1 (Technique)** : Ségrégation logique et physique des flux non essentiels par l'implémentation de règles de pare-feu.
- **Priorité 2 (Gestion des accès)** : Modification de tous les mots de passe par défaut sur les interfaces SCADA et restreindre les accès à distance aux postes d'administration avec une authentification multifacteur (MFA).
- **Priorité 3 (Organisationnel)** : Créer un groupe d'intervention avec la DSI, le directeur de l'usine et le RSSI pour définir le protocole d'arrêt d'urgence en cas de détection de compromission.

2. Contexte et périmètre de la mission

2.1 Objectifs de la démarche GRC

La discipline GRC permet d'aligner la sécurité informatique avec la stratégie globale de l'organisation. Contrairement à un audit purement technique, elle répond aux questions fondamentales sur les risques métier et la conformité.

2.2 Spécificités du secteur d'activité

L'entreprise AeroForge évolue dans le secteur de la sous-traitance aéronautique et de la production industrielle manufacturière, un écosystème avec des enjeux sécuritaires majeurs :

- **La continuité d'activité** : Une indisponibilité du système SCADA entraîne un arrêt de la chaîne de production causant des pertes financières importantes et des pénalités de retard auprès des donneurs d'ordres aéronautique.
- **Cible de la chaîne d'approvisionnement (Supply Chain)** : AeroForge agit en tant que partenaire de grands donneurs d'ordres. Compromettre cette dernière expose les acteurs majeurs du secteur.
- **Transformation numérique** : L'usine repose sur des protocoles historiques sans réelle sécurité. La nécessité moderne de connecter les systèmes au réseau bureautique expose à des menaces IT.
- **Norme réglementaire** : Le secteur manufacturier doit répondre aux exigences de NIS 2, qui impose un cadre strict en matière de sécurisation de son écosystème et de notifier en cas d'incident.

2.3 Périmètre de l'évaluation

Composant du SI	Spécification technique	Rôle métier (Usage réel)	Criticité (DICTR)
Serveur Central SCADA	Windows Server (historique), protocole Modbus/TCP	Supervision et pilotage centralisé de la chaîne de production.	Critique (D:4, I:4, C:2) La perte de disponibilité arrête

Composant du SI	Spécification technique	Rôle métier (Usage réel)	Criticité (DICTR)
			l'usine.
Automates Programmables (PLC)	Automates industriels gérant les machines à commande numérique	Exécution des ordres de production.	Critique (D:4, I:4, C:1) Risque d'intégrité impactant la sécurité physique.
Passerelle IT/OT	Routeur/Pare-feu	Assurer le routage entre la bureautique et l'usine (actuellement très permissif).	Élevée (D:3, I:3, C:3) Point de passage des attaques virales ou mouvements latéraux.
Sonde de détection OT (IDS)	IDS passif (Zeek ou Suricata)	Analyse passive du trafic industriel pour détecter des requêtes SCADA anormales.	Moyenne (D:2, I:3, C:2) Équipement de surveillance non intrusif.

2.4 Méthodologie retenue

L'analyse des risques a été menée conformément aux bonnes pratiques de la méthode française **EBIOS Risk Manager (ANSSI)**. Cette méthode est particulièrement adaptée à la modélisation des risques d'origine ciblée. La démarche s'est articulée autour du socle de sécurité existant, et de la construction de scénarios d'attaques pour évaluer les impacts directs sur l'outil de production.

3. Cadre réglementaire et normatif applicable

Cette section présente le périmètre légal auquel AeroForge est assujetti. En tant qu'acteur de la chaîne d'approvisionnement aéronautique, l'entreprise opère à la croisée d'exigences industrielles strictes et de lois de protection des données.

3.1 Le RGPD

Si l'activité de l'entreprise est industrielle, elle traite également des données à caractère personnel (fiche de paie, contrats), données de santé (médecine du travail), et des journaux de connexion et de contrôle d'accès physique (badges des opérateurs).

Exigences clés :

- Respect de la confidentialité et de l'intégrité (Art. 32).
- Notifier toute violation de données (fuite, vol, destruction) à la CNIL dans un délai de 72 heures (Art. 33).

Sanctions encourues : Jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires mondial.

Lien avec les constats : Le scénario de compromission par rançongiciel peut inclure une exfiltration de données (double extorsion). AeroForge sera alors exposé à des sanctions de la CNIL et à des plaintes de ses salariés.

3.2 La Directive NIS 2

En tant que sous-traitant critique pour l'industrie aéronautique, AeroForge est une « Entité Importante » au sens de NIS 2.

Exigences clés :

- Mesures de gestion des risques cyber et sécurisation de la chaîne d'approvisionnement.
- Mise en place de mesures techniques et organisationnelles de gestion de risques.
- Obligation de notifier ANSSI en cas d'incident majeur dans un délai de 24 heures (alerte précoce), puis 72 heures (notification complète).
- Engagement de la responsabilité personnelle de la direction en cas de négligence.

Sanctions encourues : Amendes administratives pouvant atteindre jusqu'à 7 millions d'euros ou 1,4 % du chiffre d'affaires mondial.

Lien avec les constats : L'absence de segmentation entre les réseaux IT et OT, ainsi que l'absence de procédure formelle de détection et de réponse aux incidents, constituent des manquements majeurs aux exigences fondamentales de la directive NIS 2.

3.3 Référentiels et bonnes pratiques sectorielles

Au-delà des contraintes purement légales, l'analyse s'est appuyée sur :

- **Le Guide d'hygiène informatique de l'ANSSI** : Définit les règles de base en matière gestion de mot de passe et segmentation.
- **La norme IEC 62443** : Référentiel international spécifique à la cybersécurité des systèmes d'automatisation et de commande industriels (IACS).

4. Scénario Stratégique, l'évaluation de la gravité

4.1 La source de risque

Dans le cadre de cette analyse, **la Source de Risque (SR)** retenue est un groupe cybercriminel organisé de type RaaS (Ransomware-as-a-Service).

La motivation est lucrative (extorsion de fonds).

Le niveau de ressources est important (capacité à exploiter des vulnérabilités récentes)

L'objectif stratégique consiste en la paralysie du cœur de métier de l'entreprise à savoir la production afin de maximiser une pression pour la rançon.

4.2 Cibles et impacts métiers

L'attaque vise directement les systèmes de production de l'usine d'AeroForge.

- **Valeur métier ciblée** : La continuité de la ligne de production.
- **Biens Supports visés** : Le système central de supervision (SCADA) et les automates programmables (PLCs).
- **Impacts identifiés** :
 - **Financier / Opérationnel** : Arrêt complet des machines à commande numérique entraînant une perte financière importante.
 - **Matériel** : Risque de perte définitive des pièces aéronautiques en cours de chauffe ou d'usinage si l'arrêt des machines est brutal.
 - **Sécurité physique** : Risque d'accident industriel grave pour le personnel présent sur la chaîne.

4.3 Échelle et évaluation de la gravité

Afin de mesurer les impacts de ce scénario sur l'entreprise, l'échelle de gravité suivante est

définie par la Direction :

Niveau	Cotation	Description des impacts métiers
1	Mineure	Perturbations légères, pertes financières négligeables, aucun impact sur la sécurité physique.
2	Modérée	Dégradation temporaire du service, pertes financières maîtrisables, récupération en quelques heures.
3	Grave	Arrêt prolongé d'une activité importante, pertes financières lourdes, impact fort sur l'image, risque physique léger.
4	Critique	Paralysie totale du cœur de métier, pertes financières menaçant la survie de l'entreprise, dommages matériels irréversibles ou danger vital pour les employés.

Au vu des impacts majeurs sur la capacité de production et des risques pour la sécurité physique des opérateurs de la ligne d'usinage, la gravité de ce scénario stratégique est évaluée à **4/4 (Critique)**.

5. Construction du Scénario Opérationnel

5.1 Le cheminement de l'attaque

Cible finale (Bien Support visé) : Les automates industriels (PLCs) de la ligne d'usinage.

Point d'entrée : Le portail VPN SSL (Périmètre IT).

Vecteur de propagation : Réseau Internet > DMZ IT > Réseau Interne IT > Pare-feu Industriel (règle dérogatoire) > Réseau OT (SCADA).

Le mode opératoire de l'attaquant s'articule autour d'une compromission initiale du réseau bureautique (IT), suivie d'un mouvement latéral opportuniste vers le cœur de l'usine (OT). L'attaque se déroule en trois phases distinctes :

Phase 1 : Intrusion et compromission du périmètre IT

L'acteur de la menace initie son attaque en exploitant une vulnérabilité critique récemment publiée (faille 1-day) sur l'équipement VPN SSL exposé sur Internet par AeroForge. Cette faille lui permet de contourner l'authentification et de s'introduire sur le réseau bureautique interne. Ensuite, l'attaquant compromet un serveur de rebond informatique et utilise des outils d'extraction de mémoire (de type Mimikatz) pour voler les identifiants d'un compte administrateur.

Phase 2 : Le pivot de l'IT vers l'OT

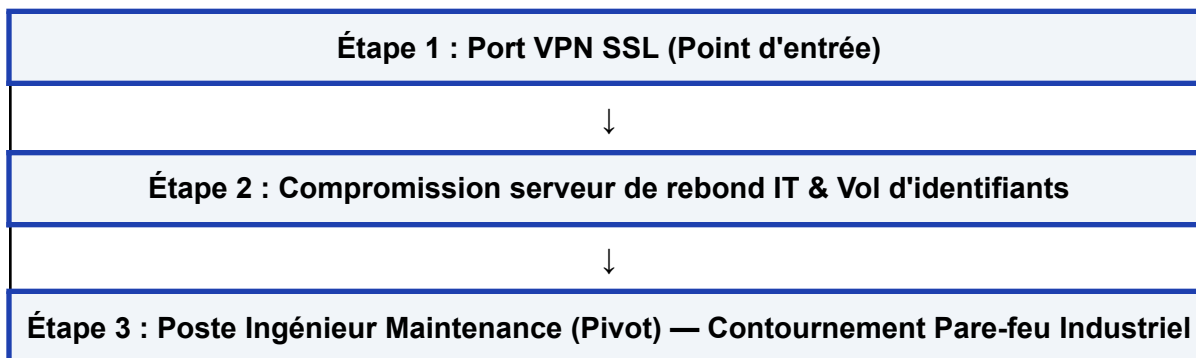
Lors de sa phase de reconnaissance interne, l'attaquant identifie le poste de travail d'un ingénieur de maintenance. En raison d'une dette technique historique ("réseau à plat"), ce poste bénéficie de règles de pare-feu dérogatoires très permissives. L'attaquant utilise ce poste compromis comme passerelle (pivot) pour franchir la barrière de sécurité séparant le réseau bureautique du réseau de production industriel (SCADA), sans déclencher d'alerte.

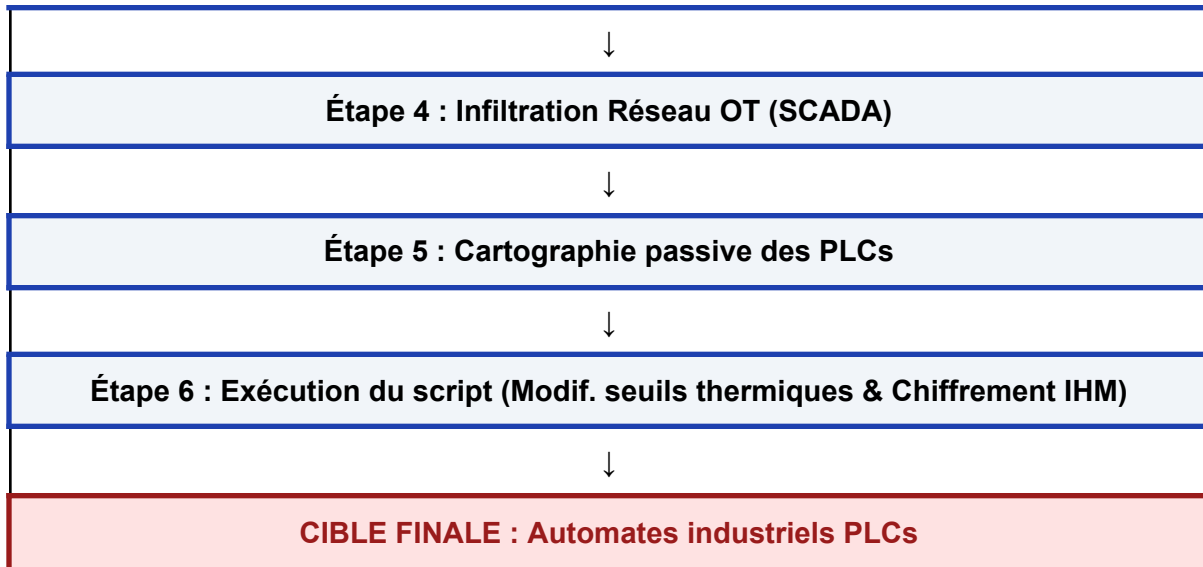
Phase 3 : Actions de sabotage sur la chaîne de production

Désormais infiltré sur le réseau industriel, l'attaquant cartographie passivement les équipements pour identifier les adresses IP des automates programmables (PLCs) contrôlant la ligne d'usinage. Il exécute ensuite un script malveillant à double effet :

1. Il modifie frauduleusement les seuils de sécurité thermique des machines à commande numérique pour provoquer une surchauffe destructrice.
2. Il chiffre simultanément les interfaces de supervision (IHM), empêchant techniquement les opérateurs de l'usine de visualiser l'anomalie en cours et de déclencher un arrêt d'urgence.

Diagramme de flux : Cheminement de l'attaque





5.2 La cartographie du scénario avec MITRE ATT&CK

La cartographie d'un scénario avec **MITRE ATT&CK for ICS** permet de traduire un récit opérationnel en éléments techniques précis (Tactiques, Techniques et Procédures - TTPs). C'est une étape clé pour faire le pont entre l'analyse de risques (GRC) et la réalité de la menace (CTI).

Puisque le scénario d'AeroForge débute sur le réseau bureautique (IT) pour s'étendre au réseau industriel (OT), la modélisation nécessite d'utiliser conjointement la matrice *Enterprise* pour l'intrusion initiale, puis la matrice *ICS* pour les actions sur la chaîne de production.

Voici la structuration de l'attaque :

Phase 1 : Intrusion et Pivot (Matrice Enterprise vers ICS)

Cette phase couvre la compromission initiale sur l'IT et l'exploitation de failles pour atteindre le réseau OT.

Étape du Scénario	Tactique (Matrice)	Technique ciblée (ID MITRE)	Justification du scénario
1. Accès initial	Initial Access (Enterprise)	Exploit Public-Facing Application (T1190)	Exploitation de la vulnérabilité sur le portail VPN SSL de l'entreprise.

2. Élévation IT	Credential Access (Enterprise)	OS Credential Dumping (T1003)	Utilisation de Mimikatz sur le serveur de rebond IT pour extraire des mots de passe.
3. Pivot IT vers OT	Initial Access (ICS)	Transient Cyber Asset (T0801)	Utilisation du poste de l'ingénieur de maintenance pour franchir le pare-feu industriel.

Phase 2 : Actions sur le réseau industriel (Matrice ICS)

Une fois l'accès obtenu au réseau SCADA d'AeroForge, l'attaquant déploie sa charge utile spécifique aux environnements de production.

Étape du Scénario	Tactique ICS	Technique ciblée (ID MITRE ICS)	Justification du scénario
4. Découverte OT	Discovery	Network Sniffing (T0842)	Écoute passive sur le réseau pour identifier les adresses IP des automates (PLCs).
5. Exécution malveillante	Execution	Scripting (T0853)	Lancement du script malveillant conçu pour interagir avec les équipements de production.
6. Sabotage (surchauffe)	Impair Process Control	Modify Parameter (T0836)	Modification des variables de contrôle des automates pour supprimer les limites de température des fours/machines.
7. Aveuglement (chiffrement)	Inhibit Response Function	Loss of View (T0827)	Chiffrement des interfaces homme-machine (IHM) du SCADA, empêchant les opérateurs de voir la

			surchauffe en cours.
8. Impact final	Impact	Damage to Property (T0806) Loss of Productivity and Revenue (T0828)	Dégâts matériels dus à la surchauffe et arrêt complet de la chaîne de production d'AeroForge.

5.3 L'échelle d'évaluation de la vraisemblance

Afin de mesurer la probabilité de succès de ce cheminement technique, l'échelle suivante, basée sur la difficulté pour l'attaquant, est utilisée :

Niveau	Cotation	Description
1	Faible	La probabilité que l'attaquant réussisse à réaliser le scénario opérationnel est très faible. Le chemin d'attaque est trop complexe ou les mesures de sécurité en place sont trop robustes par rapport au profil de l'attaquant.
2	Moyenne	L'attaquant a peu de chances de réussir. Le chemin d'attaque comporte des obstacles majeurs qui nécessitent un effort disproportionné ou une prise de risque trop importante de sa part.
3	Forte	L'attaquant a de grandes chances de réussir. Les vulnérabilités présentes dans le socle de sécurité facilitent l'exécution du chemin d'attaque sans nécessiter d'efforts exceptionnels.
4	Très Forte	L'attaquant est presque certain de réussir. Le chemin d'attaque ne rencontre aucune véritable mesure de sécurité et peut être exécuté très facilement et

		rapidement.
--	--	-------------

5.4 L'évaluation de la vraisemblance

Vraisemblance globale : 3/4 (Forte) selon l'échelle officielle EBIOS RM.

Justification : Le niveau de sécurité de l'architecture actuelle est insuffisant pour bloquer cette chaîne d'attaque. L'absence de segmentation stricte (non-respect du modèle Purdue), combinée à la présence de règles dérogatoires permissives entre l'IT et l'OT, rend le mouvement latéral très accessible pour un attaquant ayant franchi la barrière initiale du VPN.

6. Traitement des risques et Plan d'Action

6.1 L'évaluation du risque

Vraisemblance / Gravité	1 - Mineur	2 - Modéré	3 - Élevé	4 - Majeur
4 - Très élevée	Moyenne	Élevée	CRITIQUE R1	CRITIQUE
3 - Élevée	Faible	Moyenne	Élevée	CRITIQUE
2 - Modérée	Faible	Faible	Moyenne	Élevée
1 - Faible	Faible	Faible	Moyenne	Moyenne

R1 : Le niveau de risque obtenu en croisant la gravité du scénario stratégique et la vraisemblance du scénario opérationnel dans la matrice de criticité de l'entreprise.

- **Gravité (Impacts métiers) : 4/4 (Critique)** : Arrêt de ligne de production, pertes

financières majeures et risque pour la sécurité physique des opérateurs.

- **Vraisemblance (Probabilité de succès) : 3/4 (Forte)** : Exploitation d'une architecture perméable et de vulnérabilités connues sans nécessité d'efforts exceptionnels pour l'attaquant.
- **Niveau de Risque Initial : Inacceptable** : Le risque dépasse le seuil d'acceptation défini par la Direction Générale

Face à ce niveau de risque, la stratégie retenue est la “**Réduction**”. L'objectif est de déployer des mesures de sécurité pour faire chuter la vraisemblance de 3 (Forte) à 1 (Minime), afin de ramener le risque dans la zone "Moyenne" de la matrice.

6.2 Plan d'action

Réf	Mesure de Sécurité (Traitement)	Priorité	Responsable	Échéance
1	Segmentation stricte IT/OT (Modèle Purdue) : Suppression de la règle dérogatoire du poste de maintenance. Mise en place d'une zone démilitarisée industrielle (IDMZ) interdisant tout flux direct non inspecté de l'IT vers le SCADA.	Priorité 2	Responsable Réseau / Responsable OT	T4 2026
2	Déploiement d'un Bastion (PAM) : Obligation pour les ingénieurs et prestataires d'utiliser un coffre-fort de session avec rupture de protocole et enregistrement vidéo pour toute télémaintenance sur l'OT.	Priorité 2	RSSI	T3 2026
3	Gestion des correctifs (SLA 24h) : Déploiement d'une procédure d'urgence imposant l'application des correctifs critiques (CVSS > 8) sous 24 heures sur tous les équipements	Priorité 1	Administrateur système IT	Immédiat

	exposés sur Internet (ex: VPN).			
4	Mise en place de sondes OT (DPI) : Installation d'une écoute passive sur le réseau industriel pour alerter sur des commandes anormales envoyées aux automates (ex: détection de la technique MITRE <i>Modify Parameter</i>).	Priorité 3	Équipe SOC	T1 2027

6.3 Évaluation du risque résiduel

Une fois le Plan d'Action intégralement déployé et audité, le risque est réévalué de la manière suivante :

- **Gravité résiduelle** : 4/4 (Critique). La nature de l'usine fait qu'une attaque aboutie aura toujours un impact désastreux. La gravité reste inchangée.
- **Vraisemblance résiduelle** : 1/4 (Minime). L'attaquant devrait désormais découvrir une vulnérabilité inconnue (0-day) sur le VPN, contourner la rupture de protocole du Bastion, traverser la segmentation Purdue et échapper à l'analyse comportementale des sondes OT.
- **Niveau de Risque Résiduel** : **ACCEPTABLE** (sous réserve de maintien en conditions de sécurité et de tests d'intrusion annuels).

7. Conclusion et recommandations stratégiques

7.1 Synthèse de l'analyse

L'analyse de risques menée sur l'usine principale d'AeroForge a mis en évidence une vulnérabilité critique liée à l'héritage historique de son infrastructure. La convergence technologique entre les réseaux bureautiques (IT) et les systèmes de production industriels (OT), non accompagnée d'un cloisonnement strict, expose le cœur de métier de l'entreprise à des cybermenaces avancées.

Face à des groupes cybercriminels hautement structurés, le risque de paralysie de la chaîne d'usinage, entraînant des pertes d'exploitation majeures et des risques pour la sécurité physique des opérateurs, a été jugé inacceptable.

L'exécution immédiate du Plan d'Action de Cybersécurité (PAC), notamment par la

segmentation de l'architecture selon le modèle Purdue et le déploiement d'un Bastion de télémaintenance, est la condition pour ramener ce risque à un niveau tolérable et garantir la pérennité de l'outil industriel.

7.2 Recommandations stratégiques

Au-delà des mesures techniques immédiates, la sécurisation d'AeroForge nécessite une évolution de sa posture globale. Les recommandations stratégiques suivantes sont portées à l'attention de la Direction :

- **Culture de la sécurité industrielle** : Déployer un programme de sensibilisation spécifique aux ingénieurs de maintenance et aux opérateurs de la ligne de production, axé sur les risques liés aux clés USB, aux postes de supervision et aux accès distants.
- **Anticipation réglementaire** : En tant que sous-traitant dans le secteur critique de l'aéronautique, AeroForge doit faire de la cybersécurité un avantage concurrentiel. La démarche EBIOS RM initiée ici constitue un socle solide pour répondre aux futures exigences de conformité européenne (NIS 2) exigées par les donneurs d'ordres.
- **Gouvernance unifiée IT/OT** : La sécurité industrielle doit devenir une responsabilité partagée, pilotée lors d'un comité de sécurité trimestriel conjoint.
- **Résilience Opérationnelle** : La cybersécurité ne pouvant garantir un risque nul, il est impératif de mettre à jour le Plan de Continuité d'Activité (PCA) et le Plan de Reprise d'Activité (PRA) en intégrant spécifiquement des scénarios de cyberattaques sur les automates et le réseau SCADA (procédures de fonctionnement en mode dégradé manuel).

8. Annexes

8.1 Glossaire et définition

Terme	Définition
Bastion (PAM)	Équipement de sécurité agissant comme un "coffre-fort" de connexion. Il permet de contrôler, d'isoler et d'enregistrer (souvent en vidéo) toutes les interventions à distance réalisées par les administrateurs ou les prestataires sur les systèmes critiques de l'usine.
CTI	<i>Cyber Threat Intelligence</i> (Renseignement sur la menace cyber). Activité consistant à collecter et analyser des informations sur les groupes d'attaquants (motivations, outils, cibles) pour mieux anticiper les attaques.
DICTR	Acronyme des cinq critères fondamentaux de la sécurité de l'information : D isponibilité (fonctionne au besoin), I ntégrité (données non altérées), C onfidentialité (accès restreint aux ayants droit), T raçabilité (actions enregistrées) et R éversibilité (retour à un état antérieur).
DMZ	<i>Demilitarized Zone</i> (DMZ) est un sous-réseau séparé du réseau local et isolé de celui-ci ainsi que d'Internet par un pare-feu.
DPI (Sonde OT)	<i>Deep Packet Inspection</i> . Technologie d'écoute réseau analysant le trafic en profondeur. En milieu industriel, elle détecte les commandes anormales envoyées aux machines sans perturber la production.

EBIOS RM	<i>Risk Manager</i> . Méthode française d'analyse des risques cyber éditée par l'ANSSI. Elle est la référence nationale pour évaluer et traiter les risques numériques via des scénarios d'attaques ciblées.
IT	<i>Information Technology</i> . Désigne l'informatique "bureautique" ou "de gestion" (postes de travail des employés, serveurs d'emails, comptabilité, etc.).
IDS	<i>Intrusion Detection System</i> (IDS) est une application qui surveille le trafic réseau et recherche les menaces connues et les activités suspectes ou malveillantes.
MITRE ATT&CK®	Base de connaissances mondiale répertoriant les modes opératoires (tactiques et techniques) réellement utilisés par les cybercriminels. Elle sert de référence pour modéliser le comportement des attaquants.
Modèle Purdue	Architecture de référence mondiale pour la conception des réseaux industriels. Ce modèle préconise une stricte séparation par "niveaux" (segmentation) entre l'informatique de gestion (IT) et les équipements de production (OT).
NIS 2	Directive européenne visant à élever le niveau global de cybersécurité. Elle impose des exigences strictes et des sanctions financières importantes aux entreprises des secteurs critiques (dont la sous-traitance aéronautique).
OT	<i>Operational Technology</i> . Désigne l'informatique "industrielle" (matériels et logiciels qui surveillent et/ou contrôlent directement des équipements physiques, comme les machines de l'usine).

PLC (Automate)	<i>Programmable Logic Controller.</i> Ordinateur industriel très robuste utilisé pour l'automatisation. C'est le "cerveau" direct des machines à commande numérique ou des fours sur la chaîne d'usinage.
RaaS	<i>Ransomware-as-a-Service.</i> Modèle cybercriminel où des développeurs de rançongiciels louent leur code malveillant à d'autres criminels (affiliés) qui se chargent de mener l'intrusion sur les réseaux des entreprises.
SCADA	<i>Supervisory Control and Data Acquisition.</i> Système informatique centralisé offrant aux opérateurs l'interface visuelle (IHM) pour superviser et piloter l'ensemble de la ligne de production.
VPN SSL	<i>Virtual Private Network over Secure Sockets Layer</i> (VPN SSL) est une technologie qui permet à des utilisateurs distants de se connecter de manière sécurisée au réseau interne d'une entreprise en passant par Internet.

8.2 Références et sources

Cadre Méthodologique et Normatif

- ANSSI : *Méthode EBIOS Risk Manager*
- ANSSI : *Guide d'hygiène Informatique*
- ISA/IEC 62443 : *Standards pour la cybersécurité des systèmes d'automatisation et de commande industriels (IACS)*

Cadre Légal et Réglementaire

- *Directive (UE) 2022/2555 (NIS 2)*
- CNIL : *Règlement Général sur la Protection des Données (RGPD)*

Renseignement sur la Menace (Cyber Threat Intelligence)

- MITRE Corporation : *MITRE ATT&CK® Matrix for Enterprise.*
- MITRE Corporation : *MITRE ATT&CK® Matrix for Industrial Control Systems (ICS).*